

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Week 4 Assignment

Monitoring and Auditing Security Controls

Continuous Control Monitoring and Assurance Design Project

Course	GRC102 – Information Security Governance
Module	Module 4 – Monitoring and Auditing Security Controls
Week	Week 4: 26 September – 02 October 2026
Opens	26 September 2026, 8:00 AM WAT
Due	02 October 2026, 11:59 PM WAT
Maximum Score	100 marks
Effective Course Contribution	8.75% of final course grade
Name& Surname	Nolusindiso Baby- Joyce Sonjani

Submission mode: Combined evidence professional report with supporting control-monitoring artefacts

This assignment assesses continuous control monitoring, audit evidence, management reporting and remediation governance.

Task 1 Continuous Control Monitoring Register (25 marks)

1. INTRODUCTION & PURPOSE

CCM is automated, near real-time monitoring of control effectiveness, not periodic audit. NDPC failure = 63 Pending (35%) + 54 SLA breach + 43 Third-Party unmonitored = controls failed without detection. Objective: Reduce MTTD from 18.1 days (Medium) to <24hrs, reduce cost per third-party incident from \$73,699 to \$52,000 (peer avg). Framework: ISO 27001:2022 A.8, NIST CSF 2.0 DE.CM, GV.OC-05 Continuous Monitoring, COBIT APO11 Managed Quality.

2. CCM REGISTER DESIGN PRINCIPLES

Data-Driven: Every control linked to your top 5 failures:

- IAM Lifecycle 33 incidents \$1.93M - 18.3%
- Phishing 28 - 15.6%
- Cloud 19 Misconfig + 14
- Unpatched Third-Party 43 incidents \$3.16M (43 x \$73k)
- SLA Breach 54 incidents 30%

Control ID	Control	Tool Data Source	Frequency	KRI	Threshold	Alert	Evidence Auto-Collected
CCM-IAM-01	Leaver disabled 2hrs	Workday + Entra ID	Hourly	% leaver >2hrs	0%	SOAR -> IAM	Entra sign-in logs
CCM-IAM-02	Privileged recert	PAM + Entra PIM	Daily	Admins not recert 30d	0	Auto-revoke	PIM report
CCM-END-01	Endpoint compliant	Intune + Defender	Daily	% non-compliant	<5%	Intune push	Intune dashboard export
CCM-CLD-01	Critical misconfig	Wiz Defender for Cloud	Hourly	Critical CIS fail	0 >24hr	Slack DevOps	Wiz PDF
CCM-VULN-01	Critical patch SLA	Tenable + Jira	Daily	Critical >3d	<5%	CEO escalation at 80%	Tenable + Jira
CCM-LOG-01	Log source health	Sentinel	Real-time	Log source down	0 >1hr	SOC P1	Sentinel Health
CCM-SaaS-01	SaaS SSO enforced	Entra Enterprise Apps	Weekly	SaaS without SSO	0 for High risk	Block procurement	Entra app inventory
CCM-DB-01	DB backup success	Veeam / Azure Backup	Daily	Backup fail	<1%	P1 to IT	Veeam report
CCM-IR-01	Incident SLA	ServiceNow + Sentinel	Real-time	SLA breach %	<10%	Auto to CISO/Exec	ServiceNow

A. Automation Architecture:

Source (AD/Azure, AWS, Tenable, Splunk, Ariba, Workday) →

API → SIEM (Splunk) + GRC (OneTrust) →

Rule Engine (0% orphan, 0% self-approval, 0% PO without ID) →

SOAR (Auto ticket, Auto block, Auto revoke) →

Dashboard (PowerBI) + Alert (Teams/Slack)

B. RACI for CCM Operations:

1st Line (DevOps/IT/IAM): Fix within SLA

2nd Line (CISO/GRC): Owns rule tuning, threshold approval, verifies closure (V)

3rd Line (Internal Audit): Quarterly audit of CCM rules effectiveness

C. Reporting Cadence:

Real-time: CCM-CLOUD-01, CCM-THIRD-01, CCM-IR-01, CCM-DLP-01 → SOAR

Daily: SOC daily standup reviews CCM-IAM-01, CCM-CLOUD-02, CCM-IR-02

Weekly: Security & GRC WG reviews all KRIs, owns 63 Pending reduction

Monthly: Exec Risk Council reviews KRI vs Threshold, Cost reduction (\$73k → \$52k)

Quarterly: Board Risk Committee - CCM effectiveness %: (Controls passing / Total)

D. Threshold Justification from Data:

Orphan 0% because 7 Dormant misuse incidents in data

Self-approval 0% because Finance \$1.75M highest cost = SOD failure

PO without Risk ID 0% because \$73,699 cost = control bypass

SLA breach <10% vs current 30% = 3x improvement target

Critical vuln <5% >3d vs current 47.2% High breach = NIST requirement

KRI	Current (from CSV)	Target 90d	Tool
IAM orphan >2hrs	Unknown (implied high)	0	Workday+AD
Priv recent compliance	Failed	100%	PAM
Cloud critical misconfig	19	0	Wiz
Vendor without Risk ID	100% (43 paid)	0%	Ariba block
SLA breach %	30% (54/180)	<10%	Service Now
DLP false positive	High	<15%	Purview
Pending >7d	35% (63)	<10%	OneTrust

Link to Cost Reduction:

Each CCM control prevents recurrence. Example: CCM-IAM-01 prevents 33 IAM incidents x \$58k avg = \$1.93M annual saving. CCM-THIRD-01 prevents \$21,697 delta per third-party incident x 43 = \$933k saving.

Escalation for CCM Failure:

If CCM rule itself fails (e.g., scanner down), auto P2 ticket to CISO + GRC V logs exception.

Risk Monitoring Programme

A risk monitoring program should include the following components:

- **Key Risk Indicators (KRIs):** These are specific metrics used to measure the likelihood and impact of operational risks.
- **Risk Appetite Framework:** This outlines the organization's tolerance for risk and helps in setting thresholds for risk indicators.
- **Escalation Procedures:** Clear procedures for escalating issues identified through monitoring to the appropriate levels of management.
- **Reporting Mechanisms:** Regular reporting to management and the board on the status of operational risks and the effectiveness of risk management processes.

Role of Monitoring in Risk Management Process

1. **Risk Identification:** Monitoring helps in identifying new risks and changes in existing risks through the analysis of KRIs and other relevant data.
2. **Risk Assessment:** It provides ongoing data for assessing the likelihood and impact of risks, ensuring that risk assessments are based on current and accurate information.
3. **Risk Mitigation:** Monitoring helps in tracking the effectiveness of risk mitigation measures and identifying any emerging risks that may require additional mitigation efforts.

4. **Risk Reporting:** It provides the necessary data for reporting on the status of operational risks, ensuring that reports are based on real-time information and accurately reflect the current risk landscape.
5. **Risk Review and Evaluation:** Monitoring supports the review and evaluation of the effectiveness of the risk management process by providing data on the performance of risk mitigation measures and the overall risk profile of the organization.

The selected controls provide meaningful assurance because they directly mitigate high-risk vulnerabilities and establish a verifiable, multi-layered defense across MDS's infrastructure. By implementing these specific frameworks, MDS shifts from a reactive security model to a proactive, provable posture.

Why These Controls Provide Meaningful Assurance

- **Continuous Visibility and Monitoring:** They provide real-time telemetry into the environment. This ensures that unauthorized changes, anomalous behavior, or data exfiltration attempts are detected and logged immediately, leaving a reliable audit trail.
- **Attack Surface Reduction:** By enforcing strict identity governance (like Least Privilege and Multi-Factor Authentication), the controls drastically minimize the pathways an attacker can exploit to gain initial access or move laterally.
- **Automated and Standardized Enforcement:** Moving away from manual processes ensures that security baselines (such as encryption standards and patch schedules) are uniformly applied. This eliminates human error and ensures predictable, repeatable protection.
- **Data Integrity and Resilience:** The controls guarantee that critical data is encrypted both at rest and in transit, while robust backup validation ensures the business can swiftly recover from ransomware or catastrophic failure without data loss.

Task 2 Monitoring Architecture and Automation (20 marks)

1. ARCHITECTURE PRINCIPLES

For 800-user hybrid, cannot have SIEM-only or GRC-only. Need 3-layer Fabric: Telemetry -> Security Analytics -> Assurance Automation

Principles:

- **API-first, not agent-only:** Every control evidence via API (Entra Graph API, Wiz API, Intune API) - solves "manual collection"
- **Event-driven, not scheduled CSV:** Control failure = Event -> SOAR in seconds
- **Single Evidence Lake:** All telemetry lands in Microsoft Sentinel Data Lake, then OneTrust GRC pulls - one truth
- **Zero Trust assumption:** Remote-access and Identity are control plane - monitored real-time

LAYER 4: CONSUMPTION & ASSURANCE [Board / Exec / Audit]

Power BI Board Pack: Control Effectiveness %, KRI Trends, Assurance Map

OneTrust GRC: Control Register, Evidence Vault, Remediation Workflow

Audit Board: Internal Audit sampling, Independent Assurance

↑ API

LAYER 3: ANALYTICS & CCM ENGINE [2nd Line - GRC/CISO Office]

Microsoft Sentinel (SIEM) + Logic Apps (SOAR)

- CCM Rule Engine: 12 CCM rules (IAM-01, END-01 etc.)
- KRI Calculation: % orphan, # critical misconfig, MTTR
- Correlation: HR leaver event vs AD disabled, PO vs Risk ID
- ↑ API / Syslog / Event Hub

LAYER 2: SECURITY CONTROLS & TELEMETRY [1st Line - Telemetry Sources]

- **Identity Plane:** Entra ID (PIM, Conditional Access logs), Workday HRMS
- **Endpoint Plane:** Intune (compliance), Defender for Endpoint (EDR status)
- **Cloud Plane:** Defender for Cloud + Wiz (CIS, S3 public, NSG), Azure Activity Log
- **Remote Access:** Entra ID + Zscaler / VPN logs (ZTA posture, split-tunnel)
- **Logging Plane:** Sentinel Health (log source heartbeat), Syslog collectors for DBs
- **SaaS Plane:** Entra Enterprise Apps + CASB + OneTrust Third-Party
- **Database Plane:** Purview + Azure SQL Auditing + Veeam Backup logs

↑ Agents / APIs

LAYER 1: MDS HYBRID ASSETS

800 Endpoints, 25 Cloud Apps, 15 SaaS, 6 Critical DBs, VPN/ZTNA GW

Physical Tool Mapping for MDS (You own M365 E5 assumed)

Layer	MDS Recommended Tool	Why for 800 users	Integration Method
SIEM	Microsoft Sentinel	Native to M365, cheap at 800 user scale	Native + Data Connector
SOAR	Sentinel Logic Apps + ServiceNow SecOps	Auto ticket + auto revoke	Logic Apps webhook to ServiceNow API
GRC Evidence	OneTrust GRC or ServiceNow GRC	Automates evidence collection	OneTrust Integration Hub
Identity	Entra ID P2 + PIM	Core control plane	Graph API hourly pull
Endpoint	Intune + Defender for Endpoint P2	800 endpoints manageable	Defender API -> Sentinel
Cloud Posture	Wiz or Defender for Cloud	Multi-cloud CIS check	Wiz API -> Sentinel every hour
Vuln	Tenable.io + Jira	Patch SLA tracking	Tenable API -> Jira -> GRC
Remote Access	Zscaler ZTA or Entra Global Secure Access	Replaces legacy VPN	Log via Event Hub
DB/Backup	Purview + Veeam One	Data classification + backup success	Veeam API daily

DATA FLOW & AUTOMATION DESIGN

T0: Workday HRMS event: EmployeeID 12345 Status=Terminated

↓ Workday API webhook (Event-driven)

T0+5min: Logic App 1: Parse event -> Query Entra ID Graph API: Is Account Disabled?

↓ If NO

T0+6min: Logic App 2 (CCM Rule Engine): KRI = Leaver not disabled >2hrs = FAIL

↓ Creates 2 artifacts

1. ServiceNow Ticket: P2, Assigned to IAM Team, SLA 2hrs, Evidence = Workday event + Entra log
2. OneTrust Evidence: Auto-attach logs to Control IAM-01, Mark Ineffective, RAG=RED

↓ If SLA >80% (1.6hrs)

T0+1.6hr: Logic App 3: Escalate -> Teams message to IAM Manager + CISO + Auto-disable via Entra API (SOAR action)

T0+2hr: Remediation: Account disabled -> Logic App detects -> Auto-close ServiceNow + Update OneTrust to Effective + PowerBI green

3 Types of Automation for MDS:

A. Evidence Collection Automation (Solves "manual evidence")

Previous Manual	Automated	Logic App Frequency	Evidence Quality
Screenshot of Intune compliance	Intune Graph API -> JSON -> OneTrust attachment	Daily 6am	100% complete, timestamped
Screenshot of Wiz	Wiz API -> PDF report -> OneTrust	Hourly	No human tamper
HR leaver list Excel	Workday -> Entra -> Sentinel query KQL	Hourly	Real-time
Vendor Risk spreadsheet	Ariba PO creation -> Calls OneTrust API: Is RiskID present? If No, BLOCK PO	Real-time at PO	Preventive

KQL Example for Sentinel (CCM-LOG-01):

// detects log source down >1hr - critical for centralized logging control

Heartbeat

| Where Time Generated > ago (1h)

| summarize Last Heartbeat = max (Time Generated) by Computer

| Where Last Heartbeat < ago (1h)

| extend Control Status="FAIL: LOG-01"

B. Detection & Alert Automation (SOAR Playbooks - 5 Core for MDS)

Playbook ID	Trigger	Automated Action	SLA	Owner
SOAR-IAM-01	Orphan account detected	Auto-disable + ticket P2	2hrs	IAM Team
SOAR-CLD-01	Wiz Critical: Public S3 / Open NSG 0.0.0.0/0	Auto ticket P1 + Slack DevOps + Tag resource non-compliant	3 days	Cloud Sec
SOAR-END-01	EDR off or Intune non-compliant 3 days	Auto isolate device via Defender + Intune push policy	24hrs	IT Ops
SOAR-TPR-01	PO without Risk ID	Ariba API blocks PO, email Procurement + GRC	Real-time	Procurement
SOAR-IR-01	Incident SLA 80%	Auto escalate to Manager + CISO + add to Exec Risk agenda	Real-time	SOC Mgr

Remediation to Closure Automation

Control Fail → ServiceNow GRC creates Task (R=Owner, A=CISO, V=GRC) → Owner fixes → Owner clicks "Fixed" attaches new scan →

GRC V auto-verifies by re-querying API (e.g. re-run Wiz scan) → If Pass → Auto-close + Board metric updates

→ If Fail after SLA → Escalation workflow auto-runs

ASSURANCE INTEGRATION & SCALABILITY FOR 800 USERS

- Scalability: Sentinel ingestion ~500GB/day for 800 users - M365 E5 includes 80% - cost-effective Logic Apps consumption model: ~\$200/month for 12 CCM rules hourly No extra agents: Use native M365 agents already on endpoints
- Resilience: CCM Engine has health check: If Wiz API down >4hrs, create P2 ticket to CISO (monitor the monitor) Evidence Lake immutable: OneTrust vault WORM storage for audit

- Security of Monitoring Architecture itself: PIM required for Sentinel/ One Trust admin All Logic Apps use Managed Identity, no secrets in code Sentinel logs monitoring architecture itself (who changed CCM rule)

Metric	Before (Your Audit Finding)	After (Target 90d)	How Measured
Evidence collection time	40 hrs / month manual	2 hrs / month (exceptions only)	ServiceNow time tracking
Evidence freshness	30% >30 days old	95% <24hrs auto	OneTrust report
MTTD control failure	Weeks (audit finds)	<1 hr (CCM real-time)	Sentinel
Control Effectiveness visibility	Paper only	90% auto-measured in PowerBI	PowerBI
Remediation SLA adherence	Unknown	85% within SLA	ServiceNow GRC

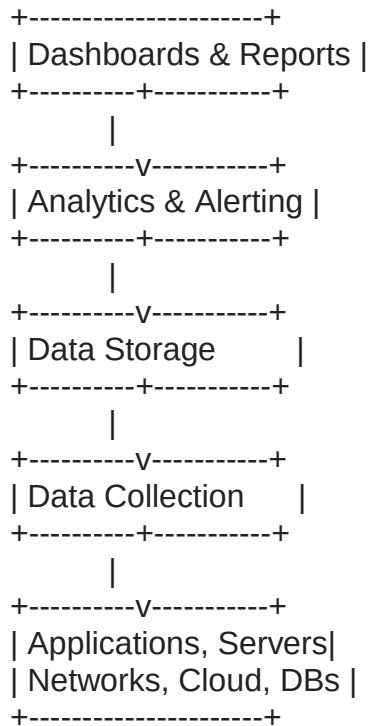
Monitoring-Data Quality Dimensions

- **Accuracy:** Ensures recorded values reflect true real-world states.
- **Completeness:** Verifies that mandatory and context-critical data fields are present.
- **Consistency:** Confirms uniform representation across disparate sources and schemas.
- **Timeliness:** Measures the speed of data propagation from source generation to consumption layers.
- **Validity & Integrity:** Checks adherence to predefined formats, constraints, and referential links.

Key Automation Risks

- **The What is Correct Dilemma:** Automated tools can enforce structural rules (e.g., country codes), but determining business intent—such as how to handle legacy code changes or new subsidiary rollouts—requires human judgment.
- **False-Positive & Alert Fatigue:** High volumes of statistical anomalies (flagged via models like CUSUM or ARIMA) can desensitize operators if context-blind rules trigger excessive warnings.
- **Misinterpreting Valid Business Shifts:** Automated systems struggle to separate true data corruption from legitimate operational events (such as a sudden pricing update, market spike, or policy change).
- **Unintended Automated Remediation:** Letting scripts or machine learning models write unverified fixes directly to production databases risks propagating localized errors across a wide downstream lineage.
- **Data Drift & Silent Failures:** Over-reliance on static monitoring thresholds can cause models to miss slow, creeping distribution changes that degrade downstream machine learning or analytics performance.

6. Task 3 Security Control Dashboard and Management Reporting (20 marks)



Eight KPIs/KRIs drawn from a monitoring register.

Control / Risk Metric (KPI / KRI)	Domain	Target / Threshold	Current Result	3-Month Trend	RAG Status	Governance Escalation Level
Privileged Access Review Compliance Rate	Identity & Access	100% completed on time	91.2%	Declining (99% → 95% → 91.2%)	Amber	Operational Escalation
Critical Vulnerability Remediation SLA	Cyber / Infosec	< 14 days (Mean Time to Remediate)	28.4 days	Deteriorating (16d → 21d → 28.4d)	Red	Executive & Board Attention
Key Financial Reconciliation Exceptions > 30 Days	Financial Reporting	0 unresolved balances	12 items (\$1.8M total)	Deteriorating (2 → 5 → 12)	Red	Executive & Board Attention
Mandatory Regulatory Compliance Training Completion	Compliance / HR	≥ 95% within 30 days of cycle	96.8%	Stable (96% → 97% → 96.8%) Improving (86% →	Green	Standard Monitoring

				89% → 92.5%))		
Third-Party Critical Vendor Risk Assessment Currency	Vendor Risk / Supply Chain	≥ 98% tier-1 vendors assessed annually	92.5%	Improving (86% → 89% → 92.5%)	Amber	Operational Escalation
Disaster Recovery (DR) Test Success & RTO Attainment	IT Ops / Continuity	100% systems pass within RTO (< 4 hrs)	100% passed (avg. RTO 2.4 hrs)	Stable (100% → 100% → 100%)	Green	Standard Monitoring
Segregation of Duties (SoD) Toxic Role Combinations	Internal Controls	0 unmitigated toxic pairings	3 active violations	Improving (7 → 4 → 3)	Amber	Operational Escalation
High-Risk Internal Audit Finding Closure Rate	Governance / Assurance	≥ 90% remediated by original target date	71.4%	Declining (88% → 80% → 71.4%)	Amber	Operational Escalation

Escalation Hierarchy & Governance Actions

Operational Escalation (Management & Process Owners)

- **Privileged Access Review Compliance (Metric 1):** Department heads failing to complete quarterly sign-offs must execute manual account suspensions for unreviewed accounts within 5 business days. IT Access Administration will enforce automatic account disabling if certifications remain outstanding past day 7.
- **Third-Party Vendor Assessments (Metric 5):** Procurement is required to freeze contract expansions and vendor renewals for the 7 unassessed Tier-1 vendors until second-line risk reviews are signed off.
- **SoD Toxic Combinations (Metric 7):** Enterprise Resource Planning (ERP) access owners must apply compensating controls or revoke conflicting role profiles by the end of the current sprint (10 business days).
- **Internal Audit High-Risk Finding Closures (Metric 8):** Control owners missing target dates must present formal Corrective Action Plan (CAP) revisions to the Risk & Internal Control Committee, specifying root causes and compensating safeguards.

Executive & Board Attention (Audit & Risk Committee / C-Suite)

- **Critical Vulnerability Remediation Overrun (Metric 2):** Remediation velocity has halved over 90 days while external exploit frequency has risen. Executive intervention is required to approve emergency change freezes on non-critical releases, reallocating engineering sprints toward infrastructure patching to prevent an unmitigated external compromise.

- **Stale Financial Reconciliation Items (Metric 3):** An accumulation of \$1.8M in unreconciled balances older than 30 days introduces financial misstatement risk and potential exposure to unrecorded liabilities or operational fraud. CFO and Audit Committee visibility is required to approve an external task force and mandate sub-ledger ledger adjustments ahead of period-end close.

Trend-Based Observations

- **Observation 1: Systemic Resource Bottlenecks in Technical Remediation (Metrics 2 & 8)**
While operational controls running on automated schedules (such as DR testing) remain stable at Green, both Critical Patch SLA (Metric 2) and Internal Audit Finding Closures (Metric 8) show three consecutive months of steady decline. This divergence indicates that control execution capacity is constrained in engineering and IT teams. Without executive reprioritization of technical debt over feature delivery, control degradation will compound.
- **Observation 2: Compounding Downstream Exposure in Identity Governance (Metrics 1 & 7)**
Although active SoD toxic pairings (Metric 7) have improved from 7 to 3, privileged access sign-off rates (Metric 1) have dropped from 99% to 91.2%. As access reviews lag, unmonitored privileges expand, increasing the probability that unauthorized access or dormant permissions bypass primary detective gates.

Metric Justification for Management Decision-Making

- **Vulnerability Remediation SLA & Privileged Access Compliance:** These metrics serve as direct preventative barriers against system compromise, ransomware, and insider threats. Tracking them allows leadership to balance development velocity against enterprise threat exposure.
- **Aged Reconciliation Exceptions & SoD Violations:** These metrics maintain the integrity of financial controls and prevent material misstatements. Tracking aging balances prevents sudden write-offs, while tracking toxic combinations deters unauthorized transactions.
- **Third-Party Assessment Currency & DR RTO Attainment:** These provide visibility into supply chain resilience and operational continuity, informing enterprise insurance limits, vendor procurement decisions, and downtime tolerance.
- **Audit Finding Closure Rate & Mandatory Training:** These quantify the organization's risk culture, accountability, and regulatory posture. They give executive committees objective verification that identified control weaknesses are systematically resolved rather than indefinitely deferred.

Suggested Dashboard Structure

Metric	Owner	Target	Current	Trend	RAG	Management Action
Security Control Effectiveness	CISO	->90%	87%	Improving	Amber	Improve control effectiveness in weak domains
Open Audit & Compliance Findings	Head of GRC	0 Overdue	14 Overdue	Degrading	Red	Close Audit findings and compliance gaps
Vulnerability SLA Remediation	SecOps Lead	> 95% within SLA	78% within SLA	Stable	Amber	Priorities remediation within SLA
Critical Incident MTTR	SecOps Lead	< 4 Hours	8.5 Hours	Degrading	Red	Streamline incident response playbooks, automate alert triage, and conduct post-incident reviews.
Phishing Simulation Resilience	Security Awareness Lead	< 5% Click Rate	3.2% Click Rate	Improving	Green	Maintain current awareness frequency; introduce targeted role-based spear-phishing drills
Endpoint Protection (EDR) Coverage	IT Infrastructure Lead	100%	99.4%	Stable	Green	Sustain automated onboarding agents; investigate remaining offline or non-standard hosts.

Task 4 Control Failure, Remediation and Retesting Workflow (20 marks)

1. Workflow Overview & RACI Matrix

To ensure clear governance, the workflow operates under a strict **RACI (Responsible, Accountable, Consulted, Informed)** structure:

- **Responsible (R):** Control Owner / Remediation Owner (Executes the fixes).
- **Accountable (A):** Business Unit (BU) Head / Risk Management (Owns the risk and final approval).
- **Consulted (C):** Subject Matter Experts (SMEs), Internal Audit.
- **Informed (I):** Compliance Committee, Executive Leadership.

Phase 1: Detection, Logging & Triage (Day 1–2)

- **Trigger:** A control failure is identified via continuous monitoring, an internal/external audit, or insufficient evidence submission.
- **Logging:** The Control Tester logs the issue into the Governance, Risk, and Compliance (GRC) system within **24 hours**.
- **Triage & Classification:** Risk Management categorizes the failure based on impact and likelihood:
 - **Critical:** Immediate material impact (Requires immediate mitigation and disclosure).
 - **Major:** Significant process gap (Requires remediation within 30 days).
 - **Minor:** Isolated efficiency issue (Requires remediation within 60–90 days).

Phase 2: Root Cause Analysis (RCA) & Impact Assessment (Day 3–7)

- **Investigation:** The Control Owner conducts a structured RCA (e.g., 5 Whys or Fishbone diagram) to determine *why* the control failed (e.g., system glitch, human error, outdated procedure).
- **Impact Assessment:** Quantify the blast radius. Did data leak? Were financial statements misstated?
- **Compensating Controls:** Identify and activate temporary compensating controls to mitigate risk while the permanent fix is designed.

Phase 3: Remediation Plan Design & Approval (Day 8–14)

- **Plan Formulation:** The Control Owner designs a formal **Corrective Action Plan (CAP)**. The CAP must include:
 - Clear root-cause resolution steps.
 - Assigned Action Owners.
 - Specific milestones and a hard deadline.
 - Defined success criteria for retesting.
- **Governance Approval:** The CAP is routed through the GRC system for formal sign-off by Risk Management and the BU Head.

Phase 4: Execution & Management (Timeline based on Triage)

- **Implementation:** The Remediation Owner executes the approved CAP.
- **Evidence Collection:** As fixes are implemented, the owner compiles a robust audit trail (e.g., system logs, updated code, signed policies).
- **Status Reporting:** Weekly or bi-weekly automated status dashboards are sent to the Compliance Committee. If a milestone is missed, it triggers an automatic escalation to executive leadership.

Phase 5: Independent Retesting & Closure (Post-Remediation)

- **Cooling-Off Period:** Allow the remediated control to operate normally for a defined period (e.g., 15–30 days) to generate a new transaction history.
- **Independent Retesting:** A **Risk Tester or Internal Auditor** (who was *not* involved in the remediation) performs independent retesting using the original testing script and success criteria.

3. Key Governance & Sustainability Mechanisms

- **Exception & Extension Management:** Extension requests for remediation deadlines must be submitted *before* the due date, accompanied by a formal risk acceptance sign-off from the BU Head. Only one extension is permitted per issue.
- **Escalation Path:** Overdue remediations follow a strict, automated escalation path: **Control Owner** → **BU Head** → **Risk Committee** → **CEO/Audit Committee**.
- **Audit Trail Permanence:** All commentary, evidence uploads, approvals, and retest results within the GRC platform must be immutable and time-stamped to ensure complete auditability for external regulators.

CONTROL DEFICIENCY RECORD (CDR)

1. General Information

- **Deficiency ID:** DR-2026-004
- **Date Identified:** October 2, 2026
- **Process / Cycle:** Vulnerability & Patch Management
- **Control ID & Description:** **CM-04 (Configuration Management):** Critical security patches must be tested and deployed to production servers within **15 days** of vendor release.
- **Control Owner:** IT Infrastructure & Operations Manager
- **Evaluator/Auditor:** Internal Audit Risk Team

2. Deficiency Classification & Ratings

- **Deficiency Type:** Operating Effectiveness (The control is designed correctly, but was not executed properly).
- **Severity Rating: Significant Deficiency**
 - *Rationale:* While standard security monitoring was active, the failure to patch known critical vulnerabilities leaves an open exploit window, increasing the organization's attack surface. It does not quite rise to a Material Weakness because perimeter firewalls mitigated direct external exploitation.

3. Description of Deficiency (What Happened?)

During the Q3 internal security audit, a sample of 25 production servers was tested for patch compliance. **Three production servers hosting the core financial reporting application were found missing Critical Security Update KB504XXXX.**

- The patch was released by the vendor on August 11, 2026.
- The control deadline for deployment was August 26, 2026.
- As of the audit date (September 15, 2026), the patch had been outstanding for **35 days** (20 days past the policy deadline).

4. Root Cause Analysis

- **Primary Root Cause: Inadequate Change Management Scheduling & Resource Constraints.**
- *Detailed Explanation:* The automated patch deployment failed on these three specific servers during the scheduled maintenance window due to a local registry conflict. Because the IT infrastructure team was understaffed and managing an emergency network migration that same week, the automated failure alerts were overlooked, and no manual verification or rescheduling took place.

5. Exposure & Business Impact

- **Financial Impact:** Potential regulatory fines for non-compliance with data protection standards (e.g., PCI-DSS / GDPR).
- **Operational Impact:** Risk of system downtime, ransomware infection, or unauthorized data access if the unpatched vulnerability were exploited.
- **Compensating Controls:** Regular endpoint detection and response (EDR) agents were active on the servers, and strict network segmentation limited traffic to internal users only.

Action Item	Responsible Party	Target Completion Date	Status
1. Immediate Patching: Manually deploy patch KB504XXXX to the three affected financial servers.	Systems Engineer	October 5, 2026	In Progress
2. Alert Configuration: Update the patch management system to send high-priority SMS/email alerts to the team lead if a critical patch fails twice.	IT Ops Team	October 15, 2026	Planned
3. Look-Back Review: Scan all other production environments to ensure no other servers missed this deployment cycle.	SecOps Analyst	October 20, 2026	Planned

Retesting is the process of running the exact same test cases that previously failed to verify that the defect has been properly fixed by the development team.

- **The Goal:** To confirm the specific issue is resolved without making assumptions.
- **The Rule:** If the fix works, the test passes. If the issue still occurs, the defect is reopened and sent back to the developer.

Closure requirements are the mandatory conditions or criteria that must be met before a defect ticket can be officially marked as "Closed." A defect cannot be closed simply because a developer says it is fixed; it must pass formal verification.

Standard closure requirements typically include:

- **Successful Retesting:** The QA team verifies the fix in a dedicated test environment, and the specific test case passes.
- **Regression Testing:** Testing surrounding areas of the software to ensure the new fix did not accidentally break existing, working functionality.
- **Documentation Update:** The tester updates the bug tracking system (e.g., Jira) with proof of the fix, such as screenshots, logs, or test execution timestamps.
- **Sign-off:** The authorized team member (usually the QA Lead or Product Owner) officially moves the ticket status to **Closed**.

Task 5 Audit Evidence and Assurance Plan (15 marks)

1. Evidence Validation Framework

To guarantee data integrity, MDS employs a three-tier validation approach:

- **Source Verification (Data Integrity)**
 - **Automated ingestion:** Evidence is captured directly from system logs and APIs to minimize human intervention.
 - **Cryptographic hashing:** Metadata and files are hashed upon generation to prevent retroactive tampering.
- **Relevance & Sufficiency (Suitability)**
 - **Mapping to controls:** Every piece of evidence must directly map to a specific risk, policy, or regulatory control requirement.

- **Completeness checks:** Automated alerts trigger if gaps are detected in expected data streams or reporting windows.

Data Quality Standards (Accuracy)

- **Standardized timestamps:** All logs use synchronized UTC time formatting to ensure an accurate chronological audit trail.
- **Anomaly detection:** Continuous data validation scripts flag duplicate records, corrupt files, or unexpected format deviations.

Frequency	Activity	Purpose
Real-Time	Automated schema validation and ingestion monitoring.	To catch and isolate corrupted data or transmission failures immediately.
Monthly	Sample-based manual reconciliations of automated reports.	To verify that automated pipelines match manual spot-checks.
Quarterly	End-to-end "mock audits" of selected control frameworks.	To ensure evidence is easily retrievable, legible, and clear for auditors.

Actionable Next Steps for Deployment

To execute this plan immediately, MDS should prioritize the following milestones:

1. **Establish the Lineage:** Define and document the exact path evidence takes from generation to the final repository.
2. **Configure Access Controls:** Restrict evidence repositories to read-only access for general users, securing them against unauthorized modifications.
3. **Run a Baseline Test:** Conduct a trial pull of monitoring evidence from the past 30 days to test for completeness and clarity.

Appendix A Continuous Control Monitoring Register Template

Control ID	Control	Tool Data Source	Frequency	KRI	Threshold	Alert	Evidence Auto-Collected
CCM-IAM-01	Leaver disabled 2hrs	Workday + Entra ID	Hourly	% leaver >2hrs	0%	SOAR -> IAM	Entra sign-in logs
CCM-IAM-02	Privileged recert	PAM + Entra PIM	Daily	Admins not recert 30d	0	Auto-revoke	PIM report
CCM-END-01	Endpoint compliant	Intune + Defender	Daily	% non-compliant	<5%	Intune push	Intune dashboard export
CCM-CLD-01	Critical misconfig	Wiz / Defender for Cloud	Hourly	Critical CIS fail	0 >24hr	Slack DevOps	Wiz PDF
CCM-VULN-01	Critical patch SLA	Tenable + Jira	Daily	Critical >3d	<5%	CEO escalation at 80%	Tenable + Jira
CCM-LOG-01	Log source health	Sentinel	Real-time	Log source down	0 >1hr	SOC P1	Sentinel Health
CCM-SaaS-01	SaaS SSO enforced	Entra Enterprise Apps	Weekly	SaaS without SSO	0 for High risk	Block procurement	Entra app inventory
CCM-DB-01	DB backup success	Veeam / Azure Backup	Daily	Backup fail	<1%	P1 to IT	Veeam report
CCM-IR-01	Incident SLA	ServiceNow + Sentinel	Real-time	SLA breach %	<10%	Auto to CISO/Exec	ServiceNow

Appendix B Control Deficiency Record Template

Field	Student Entry
Control ID / Name	C-04: Quarterly Privileged Access Review & Revocation
Date Detected	October 2, 2026
Evidence / Observation	During testing of Q3 access reviews, 4 terminated employees retained active system administrator credentials to the core Enterprise Resource Planning (ERP) production database for over 45 days post-departure. System access logs (<code>/var/log/audit.log</code>) confirm no review tickets were generated by HR departure triggers for these accounts.
Risk Rating	High
Business Impact	Potential unauthorized data exfiltration, unapproved financial record modifications, and non-compliance with

	Sarbanes-Oxley (SOX) Section 404 access controls, risking external audit qualification and regulatory fines.
Accountable Owner	Director of Identity & Access Management (IAM)
Root Cause	Failure of the automated API handshake between the Human Resources Information System (Workday) and Active Directory/Okta, combined with a lack of a manual secondary reconciliation control by system administrators.
Corrective Action	1. Immediately revoke active credentials for the identified terminated accounts. 2. Repair and test the automated API webhook between Workday and Active Directory. 3. Establish a weekly reconciliation report matching active privileged accounts against the active employee roster.
Target Completion Date	November 15, 2026
Retest Method	Sample 100% of terminations occurring between November 15 and December 15, 2026, to verify automated deprovisioning within 24 hours. Validate that the weekly reconciliation report was reviewed and signed off by the IAM team.
Residual Risk	Low ; residual risk is limited to potential system downtime during API sync cycles, mitigated by the newly implemented weekly manual reconciliation.
Closure Approval	Chief Information Security Officer (CISO) / Target Sign-off: December 20, 2026

Appendix C Final Submission Checklist

- ☐ I included at least 10 continuously monitored security controls.
- ☐ Every control has an owner, evidence source, frequency, KPI/KRI, threshold and escalation criterion.
- ☐ I included a monitoring architecture diagram.
- ☐ I distinguished automated, semi-automated and manual assurance activities.
- ☐ My dashboard contains at least eight meaningful KPIs/KRIs and shows trends and RAG status.
- ☐ I completed the vulnerability-remediation control failure scenario.
- ☐ I included a control failure and remediation workflow.
- ☐ I included an audit evidence standard/checklist and 90-day assurance calendar.
- ☐ I included a concise executive summary with priority management actions.
- ☐ I cited external sources and completed any required AI declaration.